

authentication.md — CanlıFal Kimlik Doğrulama Sözleşmesi (Web + Flutter ortak)

Kaynak: üretim kodu taraması, 2026-09-12. Bu belgedeki her uç nokta ve alan adı gerçek kaynak dosyalardan alınmıştır. Doğrulanamayan hiçbir şey uydurulmamış, **MISSING** olarak işaretlenmiştir.

1. İki paralel kimlik taşıyıcısı — TEK kullanıcı kaydı

Taşıyıcı	Kim kullanır	Nasıl	Kaynak
Mobil JWT (Authorization: Bearer <access-Token>)	Flutter	authenticate-Request(req)	lib/mobile-auth.ts
Web oturum çerezi	Tarayıcı	getServerSession(authOptions)	lib/auth-options.ts

Korumalı rotalardaki standart kalıp (gerçek kod):

```
const mobileUser = await authenticateRequest(req)
const session = !mobileUser ? await getServerSession(authOptions) : null
const userId = mobileUser?.id || session?.user?.id
if (!userId) return NextResponse.json({ error: 'Oturum açmanız gerekiyor' }, {
status: 401 })
```

Sonuç: Flutter ile web birebir aynı kullanıcı kaydını, aynı profili, aynı bakiyeyi görür. Ayrı kullanıcı/oturum sistemi yoktur.

Ölçülen kapsam: 852 endpointten **399**'u mobil JWT'yi doğrudan kabul ediyor, **133**'ü public, **366**'sı admin ucu.

2. Token formatı ve ömürleri (lib/mobile-auth.ts)

Özellik	Değer
Algoritma	HS256, sunucu sırrıyla imzalı
Access token ömrü	7 gün (ACCESS_TOKEN_EXPIRY = '7d')
Refresh token ömrü	30 gün (REFRESH_TOKEN_EXPIRY = '30d')
Payload alanları	userId , email , role , type (access veya refresh)
Header	Authorization: Bearer <accessToken>
Doğrulama önbellegi	getCachedAuth / setCachedAuth (lib/perf.ts)

authenticateRequest yalnızca type === 'access' olan tokenı kabul eder; refresh token asla Authorization başlığında gönderilmemelidir.

3. Gerçek kimlik uçları (13 rota dosyası)

3.1 POST /api/auth/mobile-register

Yeni hesap oluşturur ve token çifti döner. Kaynak: app/api/auth/mobile-register/route.ts .

3.2 POST /api/auth/mobile-login

İstek gövdesi: email (veya username) + password .

200 yanıtı (kaynaktan doğrulanmış alanlar):

```
accessToken, refreshToken,
user: { id, email, name, username, role, image,
        credits, jetonBalance, cfcBalance,
        membership, membershipExpiresAt,
        preferredLanguage, level, bio, phone,
        birthDate, zodiacSign, referralCode }
```

Hatalar: 400 eksik alan · 401 “E-posta veya şifre hatalı” · 429 “Çok fazla istek. Lütfen biraz bekleyin.” (authLimiter = 15 dakikada 10 istek, IP bazlı) · 500 .

3.3 POST /api/auth/mobile-refresh

İstek: refreshToken . 200: yeni accessToken + refreshToken + user . 401 : “Geçersiz veya süresi dolmuş token” / “Kullanıcı bulunamadı”.

3.4 Sosyal giriş

Sağlayıcı	Endpoint	Durum
Google	POST /api/auth/mobile-google	var
Apple	POST /api/auth/mobile-apple	var
TikTok	POST /api/auth/mobile-tiktok	var
Facebook	—	MISSING — kaynak kodda yok

3.5 Şifre işlemleri

POST /api/auth/forgot-password · POST /api/auth/reset-password · POST /api/auth/change-password .

3.6 Cihaz doğrulama

POST /api/auth/verify-device · POST /api/auth/reclaim-device — çoklu hesap/cihaz kötüye kullanımına karşı sunucu tarafı kontrol.

3.7 Çıkış

POST /api/auth/logout (web oturumu). Mobilde ayrıca DELETE /api/devices/fcm ile push tokenı silinmelidir. JWT stateless olduğu için sunucu tarafında iptal listesi yoktur (bkz. §7).

3.8 NextAuth

GET|POST /api/auth/[...nextauth] — yalnız web; Flutter bu uca istek atmaz.

4. Roller ve üyelik

Roller: user , fortune_teller , agency , moderator , finans , yonetici , admin .

Üyelikler: basic , gold , diamond + membershipExpiresAt .

Yetki matrisi veritabanı destekli: lib/permissions.ts (hasPermission , getRolePermissions , PERMISSION_GROUPS , SYSTEM_ROLES). Rol kontrolleri lib/rbac.ts (resolveUser , requireAuth , requireAdmin , requireFullAdmin , requireRole , requireOwnerOrAdmin).

5. Hata kodları (lib/api-response.ts → ErrorCodes)

Kimlikle ilgili kanonik kodlar: UNAUTHORIZED , FORBIDDEN , TOKEN_EXPIRED , TOKEN_INVALID , REFRESH_TOKEN_EXPIRED , ACCOUNT_DISABLED , ACCOUNT_BANNED , USER_NOT_FOUND , USER_ALREADY_EXISTS , INVALID_CREDENTIALS , EMAIL_ALREADY_TAKEN , USERNAME_ALREADY_TAKEN .

İki farklı yanıt biçimi bir arada kullanılıyor. İstemci ikisini de çözmelidir:

- Düz biçim (çoğu rota): tek `error` alanı, string mesaj.
- Sarmalı biçim (`lib/api-response.ts`): `success: false` + `error.code` + `error.message` .

6. Cihaz / push token kaydı

METHOD	ENDPOINT	AUTH	BODY	200
POST	/api/devices/ fcm	mobil JWT + web oturum	token , plat- form (android/ ios/web), ap- pVersion	success: true , deviceId
DELETE	/api/devices/ fcm	mobil JWT + web oturum	token	success: true

Doğrulama: `token` string ve en az 10 karakter olmalı, aksi halde 400 Geçerli bir push token gerekli . Kayıt `UserDevice` tablosuna `userId_token` benzersiz anahtarıyla **upsert** edilir; aynı token tekrar gönderilirse çift kayıt oluşmaz.

7. Kimlik tarafındaki gerçek eksikler (taramayla doğrulandı)

Eksik	Kanıt	Etki
Facebook girişi	<code>app/api/auth/</code> altında face- book rotası yok	Flutter'da Facebook butonu konamaz
Telefon/SMS OTP doğrulama	<code>otp</code> , <code>sms</code> , <code>phone</code> içeren en- dpoint yok	Telefon doğrulama akışı kur- ulamaz
E-posta doğrulama	Yalnızca <code>verify-device</code> var	Kayıt sonrası e-posta teyidi yok
Hesap silme	<code>delete-account</code> / <code>account</code> endpointi yok	Google Play "hesap silme" zorunluluğu karşılanmıyor
Token iptal / oturum listesi	JWT stateless, blacklist yok	Çalınan access token 7 gün geçerli kalır
Uygulama sürüm / zorunlu güncelleme ucu	<code>version</code> içeren tek uç <code>/api/ gifts/version</code>	Force-update kontrolü yapılamaz

Tamamı **eklemeli (additive)** olarak kapatılabilir; mevcut uçların hiçbirinin değişmesi gerekmez. Öneriler `flutter_integration_checklist.md` §3'te.

8. Tüm kimlik / cihaz / profil uçları (üretimden taranmış tam liste)

Toplam **36** endpoint (path+method). Kaynak: üretim kodu taraması, 2026-09-12.

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
GET	/api/auth/[...nextauth]	public	—	—	—	app/api/auth/[...nextauth]/route.ts
POST	/api/auth/[...nextauth]	public	—	—	—	app/api/auth/[...nextauth]/route.ts
POST	/api/auth/change-password	mobile JWT	—	—	currentPassword, newPassword	app/api/auth/change-password/route.ts
POST	/api/auth/forgot-password	public	RL	—	email	app/api/auth/forgot-password/route.ts
POST	/api/auth/logout	mobile JWT	—	—	—	app/api/auth/logout/route.ts
POST	/api/auth/mobile-apple	public	RL	—	—	app/api/auth/mobile-apple/route.ts
POST	/api/auth/mobile-google	public	RL	—	—	app/api/auth/mobile-google/route.ts
POST	/api/auth/mobile-login	public	RL	—	—	app/api/auth/mobile-lo-

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
						gin/ route.ts
POST	/api/auth/ mobile-re- fresh	public	—	—	—	app/api/ auth/ mobile-re- fresh/ route.ts
POST	/api/auth/ mobile-re- gister	public	RL	—	—	app/api/ auth/ mobile- register/ route.ts
POST	/api/auth/ mobile- tiktok	public	RL	—	—	app/api/ auth/ mobile- tiktok/ route.ts
POST	/api/auth/ reclaim- device	web otur- um	—	—	—	app/api/ auth/re- claim- device/ route.ts
POST	/api/auth/ reset- password	public	RL	—	password, token	app/api/ auth/re- set-pass- word/ route.ts
GET	/api/auth/ verify- device	web otur- um	—	—	—	app/api/ auth/ verify- device/ route.ts
DELETE	/api/ devices/ fcm	mobil JWT + web oturum	—	—	—	app/api/ devices/ fcm/ route.ts
POST			—	—	—	app/api/ devices/

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
	/api/devices/fcm	mobil JWT + web oturum				fcm/route.ts
GET	/api/me	mobil JWT	—	—	—	app/api/me/route.ts
PATCH	/api/me	mobil JWT	—	—	—	app/api/me/route.ts
GET	/api/membership-badges	public	—	—	—	app/api/membership-badges/route.ts
GET	/api/membership/plans	public	—	—	—	app/api/membership/plans/route.ts
POST	/api/membership/purchase	public	—	—	—	app/api/membership/purchase/route.ts
GET	/api/memberships	public	—	—	—	app/api/memberships/route.ts
GET	/api/memberships/packages	public	—	—	—	app/api/memberships/packages/route.ts
POST	/api/memberships/purchase	mobil JWT	ADMIN, RL, IDEM, LEDGER	—	payment-Method, planId	app/api/memberships/pur-

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
						chase/ route.ts
GET	/api/mes-sages	mobil JWT	—	unread-Count	—	app/api/ messages/ route.ts
GET	/api/mes-sages/ [userId]	mobil JWT	RL	—	content, imageUrl	app/api/ messages/ [userId]/ route.ts
POST	/api/mes-sages/ [userId]	mobil JWT	RL	—	content, imageUrl	app/api/ messages/ [userId]/ route.ts
PATCH	/api/mes-sages/re-quest	mobil JWT	—	—	action, message, receiverId, requestId	app/api/ messages/ request/ route.ts
POST	/api/mes-sages/re-quest	mobil JWT	—	—	action, message, receiverId, requestId	app/api/ messages/ request/ route.ts
GET	/api/ mobile/ config	public	—	platform, version	—	app/api/ mobile/ config/ route.ts
GET	/api/ mobile/ fortune- menu	mobil JWT	—	—	—	app/api/ mobile/ fortune- menu/ route.ts
GET	/api/ mobile/ home	mobil JWT	—	—	—	app/api/ mobile/ home/ route.ts
GET	/api/ mobile/ user-pro-	mobil JWT	—	—	—	app/api/ mobile/ user-pro-

METHOD	END-POINT	AUTH	ÖZELLİK	QUERY	BODY ALANLARI	KAYNAK DOSYA
	file/[userId]					file/[userId]/route.ts
POST	/api/signup	public	RL	—	—	app/api/signup/route.ts
GET	/api/verification	web oturum	RL	—	—	app/api/verification/route.ts
POST	/api/verification	web oturum	RL	—	—	app/api/verification/route.ts

GÜNCELLEME 2026-09-12 — Token İptali, Oturum Listesi ve Hesap Silme (GERÇEK KOD)

Aşağıdaki uçlar gerçek kodda uygulanmıştır (yalnız öneri değildir).

Yeni tablolar

Tablo	Amaç
RevokedToken	Tek tek iptal edilen token'ların SHA-256 özeti (tokenHash benzersiz), tokenType (access/refresh), reason , expiresAt
UserTokenRevocation	Kullanıcı bazında global çıkış damgası (userId birincil anahtar, revokedAt) — bu andan önce üretilmiş TÜM token'lar geçersiz
AccountDeletion	Silinen hesabın denetim kaydı (originalEmail , originalUsername , reason , source , status)

Doğrulama akışı

lib/mobile-auth.ts → authenticateRequest() imzayı doğruladıktan sonra lib/token-revocation.ts içindeki isTokenStillValid(token, userId, iat) fonksiyonunu çağırır:

1. Token özeti RevokedToken içinde varsa → geçersiz.

- Token'ın `iat` değeri kullanıcının `UserTokenRevocation.revokedAt` değerinden küçükse → geçersiz.
- Aksi halde geçerli.

Önbellek: iptal durumu 30 sn, kimlik doğrulama sonucu 60 sn önbelleklenir. **İptal en kötü durumda ~90 sn içinde etkili olur, anında değildir.** Veritabanına ulaşılamazsa fail-open davranır (mevcut oturumlar kopmaz).

Uçlar

Metot	Yol	Gövde	Açıklama
POST	<code>/api/auth/logout</code>	<code>{ refreshToken?, deviceToken? }</code>	Mevcut access token'ı ve verilirse refresh token'ı iptal eder; <code>deviceToken</code> verilirse <code>UserDevice</code> kaydını siler
POST	<code>/api/auth/logout-all</code>	<code>{ removeDevices?: boolean }</code>	<code>UserTokenRevocation</code> damgasını günceller → kullanıcının tüm cihazlardaki tüm token'ları geçersiz olur
GET	<code>/api/auth/sessions</code>	—	Kayıtlı cihazlar + <code>lastGlobalLogoutAt</code>
DELETE	<code>/api/auth/sessions? deviceId=...</code>	—	Tek cihazı kaldırır

Refresh yarış koruması

`/api/auth/mobile-refresh` :

- İptal edilmiş refresh token → `401 TOKEN_REVOKED` .
- Aynı refresh token 15 sn içinde birden fazla kez gelirse aynı yanıt döndürülür (süreç içi tekilleştirme)
- eşzamanlı iki isteğin birbirini geçersiz kılması engellenir.

Hesap silme (Google Play zorunluluğu)

Metot	Yol
DELETE	<code>/api/user/account</code>
POST	<code>/api/user/account</code> (aynı davranış)
POST	<code>/api/user/account/delete</code> (takma ad)

Gövde: `{ confirm: true, password?: string, reason?: string }`

- `confirm` yoksa → `409` + `requiresConfirmation: true` .
- Parola ile kayıtlı hesapta `password` zorunludur (bcrypt ile doğrulanır).

- Zaten silinmiş hesap → tekrar silinemez.
- Akış: aktif yayınlar ended yapılır → kişisel veriler anonimleştirilir → ilişkili kayıtlar silinir → tüm token'lar iptal edilir → AccountDeletion kaydı yazılır → recordAudit('user.account_deleted') .
- Finansal defter (ledger) kayıtları **muhasabe bütünlüğü için silinmez**, kullanıcıyla bağlantısı anonimleştirilir.

E-posta doğrulama (BÖLÜM 17)

Metot	Yol	Auth	Açıklama
POST	/api/auth/email/send-verification	mobil JWT / web oturumu	Oturum açan kullanıcıya 24 sa geçerli doğrulama bağlantısı gönderir. E-posta zaten doğrulanmışsa alreadyVerified: true . Rate-limit uygulanır.
POST	/api/auth/email/verify	public (token)	Gövde { token } . Token'ı tüketip User.emailVerified alanını doldurur.
GET	/api/auth/email/verify?token=...	public (token)	Tarayıcı bağlantısı ile doğrulama (aynı mantık).

- Token randomBytes(32) hex, email_verification_tokens tablosunda tutulur, tek kullanımlık, süre 24 sa. Yeni istek önceki kullanılmamış token'ları geçersiz kılar.
- E-posta gönderimi mevcut bildirim altyapısı ile yapılır (NOTIF_ID_EPOSTA_DORULAMA). Bağlantı: /e-posta-dogrula?token=... .

Telefon/SMS OTP doğrulama (BÖLÜM 17)

Metot	Yol	Auth	Açıklama
POST	/api/auth/phone/send-otp	mobil JWT / web oturumu	Gövde { phone } . 6 haneli, 5 dk geçerli OTP gönderir. Rate-limit uygulanır.
POST	/api/auth/phone/verify-otp	mobil JWT / web oturumu	Gövde { phone, code } . Doğruysa User.phone kaydedilir ve phoneVerified: true olur. En fazla 5 deneme.

- OTP kodları phone_otps tablosunda tutulur (attempts sayacı ile). normalizePhone() TR için varsayılan +90 ekler.
- **Yapılandırma gerekli:** SMS_PROVIDER (netgsm | twilio) + sağlayıcı kimlik bilgileri. Ayarlanmadan uç 503 SERVICE_UNAVAILABLE döner ve kod göndermez.

Hâlâ olmayan

- Telefon numarası ile **giriş** (login) akışı yok; OTP yalnız doğrulama amaçlıdır.
- E-posta/telefon doğrulama zorunlu tutulmaz (uygulama akışı isterse zorunlu kılabilir).